

Secrets & Configuration

Separate non-secret settings from credentials • Explain the known migration gap

SAY IT IN THE INTERVIEW

"I keep environment-specific endpoints separate from Java code and override them for Docker deployment. Docker Hub authentication uses Jenkins Credentials. I also identified a remaining issue: database passwords are still in tracked Spring properties. That needs rotation and externalization; I do not present it as already fixed."

01 WHICH SETTING GOES WHERE?

- **Repository:** topic names, ports, retry policy and safe default addresses. These describe behavior and are not authentication secrets.
- **Runtime environment:** values such as `SPRING_DATASOURCE_URL` and `SPRING_KAFKA_BOOTSTRAP_SERVERS` adapt the app to the host or Docker network.
- **Secret store/local override:** actual passwords and tokens. A Jenkins credential ID is a reference, not the secret value. See Chapter 12 for the implemented Docker Hub binding.

02 TWO EASY CONFIGURATION MISTAKES

- An ignored `.env` is not automatically read by Spring Boot. Compose interpolation only helps when the Compose file references the relevant variables.
- An ignored `application-local.properties` file needs the corresponding `local` profile activated. Ignoring a file does not make Spring load it.
- Current Compose has SMTP disabled and does not wire the optional SMTP placeholders into Grafana. Copying `.env.example` alone does not enable email.

03 THE DATABASE GAP — EXPLAIN THE SAFE FIX

- Tracked main/test Spring properties currently contain DB passwords; the deployment does not inject an external DB password. Never display their values in notes or demos.
- Migration plan: rotate the credential → configure Jenkins Credentials → externalize the Spring setting → pass `SPRING_DATASOURCE_PASSWORD` to tests/deployment → verify both services.
- Configure an ignored local override for development. Verify Jenkins has the new credential before removing its current dependency, so the pipeline is not silently broken.

04 WHAT IGNORE RULES DO NOT SOLVE

- The repository ignores `.env` and local Spring override files. This reduces accidental future commits; it does not untrack existing files or erase prior Git history.
- Deleting a committed password from the latest file is not rotation. Treat the old credential as exposed and replace it.
- ngrok tokens, webhook secrets and SMTP credentials must stay out of screenshots, logs and Git. Kafka uses PLAINTEXT here; TLS/ACL hardening is not a current guarantee.

YAAD RAKHO: ignored ≠ loaded; removed from latest file ≠ secret rotated.